

Here is the translated and structured system architecture, optimized as a clear data flow and process specification that any AI can easily read, parse, and map out.

1. System Architecture & IP Addressing Matrix

The network is structured using VLAN segmentation to strictly isolate out-of-scope (OOS) environments from the Cardholder Data Environment (CDE).

- **Retail Store (Origin):**
 - Retailer POS: VLAN 10, IP 192.168.10.20/24.
 - Retailer Router: VLAN 10, IP 192.168.10.1/24.
- **DMZ & Edge Filtering:**
 - Perimeter Firewall (External): IP 192.168.10.254/24.
 - Perimeter Firewall (Internal): VLAN 20, IP 10.0.10.1/24.
 - DMZ Server: VLAN 20, IP 10.0.10.10/24.
- **Switch 1 (OOS Network & Jumpbox Distribution):**
 - Switch 1: VLAN 50, IP 10.50.1.2/24.
 - Branch Manager: VLAN 51, IP 10.50.51.10/24.
 - Operation Manager: VLAN 52, IP 10.50.52.10/24.
 - Compliance Officer: VLAN 53, IP 10.50.53.10/24.
 - Finance Manager: VLAN 54, IP 10.50.54.10/24.
 - IT: VLAN 55, IP 10.50.55.10/24.
 - IT Security: VLAN 56, IP 10.50.56.10/24.
 - Jumpbox: VLAN 99, IP 10.50.99.10/24.
- **Switch 2 & Internal Perimeter (CDE):**
 - Internal Firewall (CDE Facing): IP 10.100.1.1/24.
 - Switch 2: VLAN 100, IP 10.100.1.2/24.
- **Cardholder Data Environment (CDE):**
 - Application Server: VLAN 110, IP 10.100.10.10/24.
 - Key Management System (KMS): VLAN 120, IP 10.100.20.10/24.
 - Database (PostgreSQL): VLAN 130, IP 10.100.30.10/24.
- **Logging Operations:**
 - Log Server: VLAN 200, IP 10.200.10.10/24.

2. Network Access Control & Segmentation Rules

- **Department Isolation (OOS):** All department VLANs on Switch 1 are isolated using ACLs with a default deny policy, meaning they cannot communicate with each other.
- **Jumpbox Routing:** All Out-Of-Scope (OOS) department VLANs are authorized to reach the Jumpbox IP. However, progressing past the Jumpbox into the CDE requires strict authorization and Multi-Factor Authentication (MFA), enforcing "business need-to-know" access restrictions.
- **CDE Micro-segmentation:** The Internal Firewall enforces a default deny policy for the CDE. The Application Server is exclusively allowed bidirectional communication with the KMS and Database. The KMS and Database automatically reject any connection attempts that do not originate directly from the Application Server, completely isolating them from one another and external entities.

3. End-to-End Data Processing Flow

Phase 1: Transaction Entry & Transit

- A transaction is initiated at the Retailer POS (VLAN 10).
- Data is encrypted via TLS 1.2 to prevent interception or packet sniffing while in transit.
- The encrypted payload is routed to the Perimeter Firewall and passed to the DMZ Server for initial filtering.

Phase 2: DMZ to Application Processing

- The DMZ Server forwards the validated data through Switch 1 to the Internal Firewall.
- The Internal Firewall inspects and forwards the traffic through Switch 2 to the Application Server (VLAN 110).
- Upon receipt, the Application Server splits the payload in memory. It immediately verifies and disposes of Sensitive Authentication Data (SAD). It masks the Primary Account Number (PAN) and prepares the remaining card data for encryption.

Phase 3: Cryptography & Tokenization

- The Application Server routes the sensitive card data to the KMS (VLAN 120).
- The KMS executes AES-256 encryption on the raw data (producing **Encrypted_CHD**) and generates a reference token (**Card_Token**). Raw cryptographic keys never leave the KMS.
- The KMS returns the **Card_Token** and **Encrypted_CHD** back to the Application Server.
- The Application Server permanently discards any remaining raw card data from its active memory.

Phase 4: Persistence

- The Application Server writes the securely masked PAN, Token, and Ciphertext to the isolated PostgreSQL Database (VLAN 130).

4. Data Schema Definition

To prevent overhead during simulation while maintaining strict compliance, data is split into two tables to segregate identity from secure artifacts.

Customers Table (Identity / Authentication):

- **Customer_ID** (Integer)
- **Full_Name** (Varchar)
- **Email** (Varchar)
- **Phone_Number** (Varchar)
- **Created_At** (Datetime)

Transactions Table (Secure Persistence):

- **Tx_ID** (Integer)
- **Customer_ID** (Integer)
- **Tx_Amount** (Decimal)
- **Masked_PAN** (Varchar) - *e.g., *****4242
- **Card_Token** (Varchar) - e.g., tok_a91f33
- **Encrypted_CHD** (Text) - e.g., gAAAAABKX1...
- **Tx_Timestamp** (Datetime)

5. Centralized Audit & Logging Strategy

An isolated Log Server (VLAN 200) passively collects telemetry from crucial infrastructure components to validate segmentation and track security events. Targeted components for log collection include:

- **Firewalls:** Collects traffic events, drop logs, and configuration changes.
- **Jumpbox:** Records login attempts, remote SSH sessions, session duration, and MFA authentication results.
- **Application Server:** Tracks API requests, user activity, and processing errors.
- **KMS:** Logs key generation operations, access attempts, and auto-reject events.
- **Database:** Records query executions, transaction commits, and access logs.